

PENETRATION TESTING FUNDAMENTALS

MODULE 5

Exploiting Network-Based Vulnerabilities

Student Study Guide

Topics: NetBIOS/LLMNR · SMB/EternalBlue · DNS Poisoning · SNMP · SMTP · FTP · Pass-the-Hash · Kerberos · MITM/On-Path · DoS/DDoS · VLAN Hopping · Wireless Attacks · Bluetooth/RFID · Password Spraying

1. Introduction: Network-Based Vulnerabilities

Network-based vulnerabilities and exploits can be catastrophic because of the types of damage and impact they can cause in an organisation. The following are the major categories of network-based attacks covered in this module:

- Windows name resolution-based attacks and exploits (NetBIOS, LLMNR)
- DNS cache poisoning attacks
- Attacks and exploits against Server Message Block (SMB) implementations
- Simple Network Management Protocol (SNMP) vulnerabilities
- Simple Mail Transfer Protocol (SMTP) vulnerabilities
- File Transfer Protocol (FTP) vulnerabilities
- Pass-the-hash attacks
- On-path attacks (previously known as man-in-the-middle [MITM] attacks)
- SSL stripping attacks
- Denial-of-service (DoS) and distributed DoS (DDoS) attacks
- Network access control (NAC) bypass
- Virtual LAN (VLAN) hopping attacks
- Wireless, Bluetooth, and RFID attacks
- Password spraying and exploit chaining

2. Windows Name Resolution: NetBIOS, LLMNR & SMB

2.1 Name Resolution Overview

Name resolution is one of the most fundamental aspects of networking and operating systems. Several technologies handle name-to-IP address resolution, including NetBIOS, Link-Local Multicast Name Resolution (LLMNR), and DNS.



NetBIOS and LLMNR are primarily used by Microsoft Windows for host identification. A Windows host trying to communicate with a printer or a network shared folder may use NetBIOS.

NetBIOS Services

- NetBIOS Name Service (NetBIOS-NS) — for name registration and resolution
- Datagram Service (NetBIOS-DGM) — for connectionless communication
- Session Service (NetBIOS-SSN) — for connection-oriented communication

Key Ports — NetBIOS & SMB

Port / Protocol	Service	Notes
TCP 135	Microsoft RPC (MS-RPC)	Endpoint mapper — client-to-client and server-to-client communication
UDP 137	NetBIOS Name Service	Name registration and resolution
UDP 138	NetBIOS Datagram Service	Connectionless communication
TCP 139	NetBIOS Session Service	Connection-oriented communication
TCP 445	SMB	File sharing between Windows and Unix-based systems
UDP 5355	LLMNR	Link-Local Multicast Name Resolution

NOTE

Traditionally, a NetBIOS name was a 16-character name assigned to a computer in a workgroup by WINS. Microsoft now uses DNS for name resolution. The default workgroup name in Windows is WORKGROUP — many users leave this default and configure file/printer sharing with weak credentials.

2.2 LLMNR Poisoning Attack

LLMNR / NBT-NS Poisoning

A common vulnerability in LLMNR involves an attacker spoofing an authoritative source for name resolution on a victim system by responding to LLMNR traffic over UDP port 5355 and NBT-NS traffic over UDP port 137. The attacker poisons the LLMNR service to manipulate the victim's system.

If the requested host belongs to a resource that requires authentication, the victim's username and NTLMv2 hash are sent to the attacker. The attacker captures these hashes and can then brute-force or crack them offline to obtain plaintext passwords.

Tools for LLMNR Poisoning

- **Responder:** The most popular tool for LLMNR/NBT-NS poisoning — intercepts hashes automatically
- **NBNSpoof:** Spoofs NetBIOS name service responses
- **Metasploit:** Includes modules for LLMNR and NBT-NS poisoning
- **Pupy:** Python-based cross-platform remote administration and post-exploitation (Windows, Linux, macOS, Android)



TIP

Mitigations: Disable LLMNR and NetBIOS in local computer security settings or via Group Policy. Block LLMNR/NetBIOS traffic at the network level if not needed. Detection: Monitor registry key HKLM\Software\Policies\Microsoft\Windows NT\DNSClient for changes to the EnableMulticast DWORD. A value of 0 means LLMNR is disabled.

2.3 SMB Exploits

SMB has historically suffered from numerous catastrophic vulnerabilities. Use the `searchsploit smb` command in Kali Linux to see dozens of well-known SMB exploits in the Exploit Database (exploit-db.com).

✱ EternalBlue (MS17-010)

EternalBlue is one of the most impactful SMB exploits in history. It was leaked by an entity called the Shadow Brokers, who allegedly stole numerous exploits from the U.S. National Security Agency (NSA).

Successful exploitation allows an unauthenticated remote attacker to compromise an affected Windows system and execute arbitrary code. EternalBlue was used in the WannaCry and NotPetya ransomware attacks and has been ported to Metasploit.

To find the exact location of the EternalBlue exploit in Metasploit, use the search command: `search eternalblue`

3. DNS Cache Poisoning



DNS Cache Poisoning

DNS cache poisoning involves the injection of corrupted DNS data into a DNS resolver's cache. This forces the DNS server to return a wrong IP address to the victim, redirecting them to the attacker's system instead of the legitimate server. Attacks can also combine social engineering to trick victims into downloading malware or entering sensitive data.

Mitigations

- Configure DNS servers to rely as little as possible on trust relationships with other DNS servers
- Use BIND 9.5.0+ — provides randomisation of ports and cryptographically secure DNS transaction IDs
- Limit recursive DNS queries — restrict query responses to only the requested domain
- Implement DNSSEC (DNS Security Extensions) — developed by the IETF for secure DNS data authentication
- Store only data related to the requested domain — never cache unsolicited records

4. SNMP Exploits

4.1 What Is SNMP?

Simple Network Management Protocol (SNMP) is used to manage network devices. Every SNMP-enabled device runs an SNMP agent that connects with an SNMP manager (server). Administrators use SNMP to get health information and configurations, and to change configurations remotely.

Version	Authentication	Security Level
SNMPv1	Community strings (plaintext)	No encryption — never use in production
SNMPv2c	Community strings (plaintext)	Most widely deployed but insecure — default passwords 'public'/'private'

SNMPv3	Username and passwords	Supports authentication and encryption — use this version
---------------	------------------------	---

NOTE

The managed device information is stored in a database called the Management Information Base (MIB). A common SNMP attack involves enumerating SNMP services and checking for default credentials ('public' for read-only, 'private' for read/write).

SNMP Tools

- **Nmap NSE scripts:** Gather information from SNMP-enabled devices and brute-force weak credentials. NSE scripts are located at `/usr/share/nmap/scripts` by default in Kali Linux
- **snmp-check:** Performs an SNMP walk to gather detailed information from SNMP-enabled devices

TIP

Always change default SNMP community strings. Limit SNMP access to trusted hosts only. Block UDP port 161 from untrusted systems. Use SNMPv3 exclusively. Consider NETCONF for modern network devices.

5. SMTP Exploits

5.1 Email Protocol Ports

Before exploiting email protocol vulnerabilities, you must understand the standard ports used by different email protocols:

Port / Protocol	Service	Notes
TCP 25	SMTP	Default port for non-encrypted email server-to-server communication
TCP 465	SMTPS	SMTP over SSL — registered by IANA but now deprecated in favour of STARTTLS
TCP 587	SSMTP (STARTTLS)	Secure email submission by Mail User Agents (MUAs) — defined in RFC 2487

TCP 110	POP3	Default non-encrypted POP3 — used to receive emails
TCP 995	POP3S	Encrypted POP3
TCP 143	IMAP	Default non-encrypted IMAP — used to receive and manage emails
TCP 993	IMAPS	Encrypted IMAP over SSL/TLS

 NOTE

SMTP is used to SEND emails (server-to-server protocol). POP3 and IMAP are used to RECEIVE emails (client/server protocols). This distinction is important for understanding which attack surface each protocol presents.

5.2 SMTP Open Relays

An SMTP open relay is an email server that accepts and forwards emails from any user, without authentication. This can be abused to send spoofed emails, spam, phishing, and other email-based attacks. Nmap includes an NSE script to test for open relay configurations: `smtp-open-relay.nse`.

5.3 Useful SMTP Commands for Security Evaluation

Command	Purpose
HELO	Initiates an SMTP conversation (followed by IP or domain, e.g. HELO 10.1.2.14)
EHLO	Initiates a conversation with an Extended SMTP (ESMTP) server
STARTTLS	Starts a TLS connection to an email server
RCPT	Specifies the recipient's email address
DATA	Initiates transfer of the email message content
RSET	Resets (cancels) an email transaction
MAIL	Specifies the sender's email address
QUIT	Closes the connection
VRFY	Verifies whether a user's mailbox exists — DISABLE on production servers
EXPN	Requests/expands a mailing list — DISABLE on production servers

AUTH

Authenticates a client to the server

 TOOL

smtp-user-enum (installed by default in Kali Linux) automates user enumeration via SMTP. It uses VRFY and EXPN commands to verify whether users exist on the mail server. Most modern email servers disable these commands — and you should too.

6. FTP Exploits

The legacy FTP protocol does not use encryption or integrity validation. Attackers abuse FTP servers to steal information, and an attacker who compromises a system can use FTP as a stepping stone for exfiltrating data to an anonymous FTP server.

Protocol	Transport	Security
FTP	Plain TCP	No encryption, no integrity validation — avoid entirely in production
FTPS	FTP over TLS	Encrypts data — use strong ciphers (AES), disable MD5/SHA-1
SFTP	SSH	Encrypts data and uses SSH for authentication — preferred solution

FTP Security Best Practices

- Use strong passwords and MFA — never rely on anonymous authentication
- Implement file and folder security — users should access only files they are entitled to
- Encrypt all files stored on the FTP server (encryption at rest)
- Lock down admin accounts — restrict privileges, require MFA, avoid 'root' or 'admin' usernames
- Keep FTPS/SFTP server software up to date — patch promptly
- Use FIPS 140-2 validated encryption ciphers (guidance on acceptable algorithms)
- Keep back-end databases on a different server from the FTP server
- Require re-authentication for inactive sessions

7. Pass-the-Hash Attacks

All versions of Windows store passwords as hashes in the Security Accounts Manager (SAM) file. The OS never stores the actual plaintext password — only its hash. Microsoft created its own hashing implementation that has evolved through NTLMv1, NTLMv2, and Kerberos.

KEY CONCEPT

Because Windows hashes cannot be reversed directly, an attacker doesn't need the plaintext password. In a pass-the-hash attack, the attacker captures the hash from a compromised system and uses that hash directly to authenticate to another system — bypassing the need to know the actual password.

How Pass-the-Hash Works

1. Attacker compromises a Windows system
2. Extracts password hashes from the SAM file or from memory
3. Uses the captured hash directly in an authentication request to another target system
4. The target system accepts the hash as valid authentication — without ever knowing the plaintext password

NOTE

NTLM is still used when: (1) the client authenticates to a server via IP address, (2) the client authenticates to a server in a different AD forest configured for NTLM trust, (3) the target doesn't belong to a domain, or (4) Kerberos is blocked by a firewall.

TOOL

Mimikatz — the most widely used tool for retrieving password hashes from Windows memory. Used by penetration testers, attackers, and malware alike. Download: github.com/gentilkiwi/mimikatz Metasploit includes Mimikatz as a Meterpreter script — no files need to be written to disk on the compromised host. Details: offensive-security.com/metasploit-unleashed/mimikatz/

8. Kerberos and LDAP-Based Attacks

8.1 Kerberos Overview

Kerberos is an authentication protocol defined in RFC 4120, used by Windows domains, numerous applications, and other operating systems. It is an authentication protocol — not an authorisation or encryption system (though it uses encryption internally).

Kerberos Element	Role
Client	The user or service requesting access to a resource
Server	The target resource being accessed
Key Distribution Centre (KDC)	Contains the Authentication Server (AS) and Ticket-Granting Server (TGS) — the heart of Kerberos

NOTE

Active Directory uses LDAP (Lightweight Directory Access Protocol) as its access protocol, and the Windows LDAP implementation supports Kerberos authentication. LDAP uses an inverted-tree structure called the Directory Information Tree (DIT). Every entry has a Distinguished Name (DN) representing its full path.

8.2 Kerberos Golden Ticket Attack

Golden Ticket Attack

An attacker compromises a vulnerable system, obtains local user credentials and password hashes, and identifies the Kerberos KRBTGT (Ticket-Granting Ticket) password hash. With this hash, the attacker can forge any Kerberos ticket — gaining access to any resource in the domain without needing any other credentials.

TOOL

Empire — a post-exploitation framework with a pure-PowerShell Windows agent and Python agent. Can perform golden ticket and many other Kerberos attacks. Runs PowerShell agents without needing powershell.exe. Download: github.com/BC-SECURITY/Empire

8.3 Kerberos Silver Ticket Attack

Silver Ticket Attack

Silver tickets are forged service tickets for a specific service on a particular server (not domain-wide like a golden ticket). To forge a silver ticket, an attacker needs: the system account

(ending in \$), the domain SID, the FQDN, and the target service name (e.g. CIFS, HOST). Services such as Windows CIFS allow file access; HOST allows schtasks.exe or WMI execution.

8.4 Unconstrained Kerberos Delegation

Kerberos delegation allows an application to reuse end-user credentials to access resources on a different server. Unconstrained delegation is dangerous because any user connecting to an application server with unconstrained delegation enabled can have their TGT captured by an attacker who has compromised that server. Kerberos delegation is not enabled by default in Active Directory.

8.5 Kerberoasting

Kerberoasting

Kerberoasting is a post-exploitation technique that extracts service account credential hashes from Active Directory for offline cracking. It exploits a combination of weak encryption and poor password practices.

Why it's powerful: The attacker can extract service account hashes **WITHOUT** sending any IP packets to the victim and **WITHOUT** domain admin credentials. The hashes are then cracked offline.

9. On-Path (MITM) Attacks

In an on-path attack (previously called a man-in-the-middle attack), the attacker places themselves inline between two communicating devices to eavesdrop, steal sensitive data, or manipulate data being transferred. On-path attacks can happen at Layer 2 or Layer 3.

9.1 ARP Cache Poisoning (ARP Spoofing)

ARP Cache Poisoning

ARP spoofing targets hosts, switches, and routers connected to a Layer 2 network by poisoning their ARP caches. The attacker intercepts traffic intended for other hosts on the subnet. MAC spoofing accompanies ARP poisoning — the attacker impersonates the MAC address of another device (typically a router) to redirect traffic.

 NOTE

Mitigation: Use Dynamic ARP Inspection (DAI) on switches to prevent spoofing of Layer 2 addresses.

9.2 STP Manipulation (Layer 2)

An attacker can place a switch in the network and manipulate Spanning Tree Protocol (STP) to make it become the root switch. Any traffic that passes through the root switch can be intercepted by the attacker. Countermeasure: Use BPDU Guard and Root Guard features on access switch ports.

9.3 Rogue Router (Layer 3)

An attacker places a rogue router on the network and tricks other routers into believing it has a better (shorter or more specific) path. Victim traffic is redirected through the attacker's router. An attacker can also compromise a victim's system and install malware that intercepts packets before encryption occurs.

9.4 SSL Stripping

 SSL Stripping

SSLStrip is an on-path attack tool that transparently intercepts HTTPS traffic, downgrades it to HTTP, and returns non-encrypted links to the victim. Created by security researcher Moxie Marlinspike. Download: github.com/moxie0/sslstrip

9.5 Layer 2 Security Best Practices

- Use an unused VLAN (not VLAN 1) as the native VLAN for all trunks — VLAN 1 is the default and should be avoided
- Administratively configure switch ports as access ports — disable DTP (Dynamic Trunking Protocol) negotiation
- Limit MAC addresses learned on a port using port security
- Use BPDU Guard and Root Guard to control Spanning Tree
- Disable CDP on ports facing untrusted networks (CDP operates at Layer 2 and can leak infrastructure details)
- On new switches: shut down all ports, assign to an unused 'parking lot' VLAN, then bring up ports as needed

- Use DAI (Dynamic ARP Inspection) to prevent ARP spoofing
- Use IP Source Guard to prevent Layer 3 spoofing by hosts
- Implement 802.1X for identity-based access control before allowing network communication
- Use DHCP snooping to prevent rogue DHCP servers
- Use storm control to limit broadcast/multicast traffic and prevent broadcast storms
- Deploy ACLs (Layer 2 and Layer 3) for traffic control and policy enforcement

10. Downgrade Attacks & Route Manipulation

10.1 Downgrade Attacks

In a downgrade attack, an attacker forces a system to use a weaker encryption protocol or hashing algorithm that is susceptible to known vulnerabilities.



POODLE — Padding Oracle on Downgraded Legacy Encryption

POODLE was an OpenSSL vulnerability that allowed an attacker to force TLS negotiation down to a lower (weaker) version between client and server. Patched since 2014, but removing backward compatibility is the only reliable prevention for downgrade attacks in general. Reference: cisa.gov

10.2 BGP Hijacking (Route Manipulation)



BGP Hijacking

Border Gateway Protocol (BGP) is the dynamic routing protocol used to route Internet traffic. An attacker configures or compromises an edge router to announce prefixes not assigned to their organisation. If the malicious route is more specific or presents a shorter path than the legitimate route, victim traffic is redirected to the attacker. Threat actors have leveraged unused prefixes to avoid attracting attention from legitimate users.

11. Denial-of-Service (DoS) and DDoS Attacks

Attack Type	Description	Example
Direct DoS	The attacker generates and sends packets directly to the victim	SYN flood, buffer overflow crash, ping flood
Botnet DDoS	A network of compromised machines (laptops, routers, IoT) controlled by a C2 server to flood the victim	Mirai botnet IoT DDoS — exploited IP cameras and home routers
Reflected DoS	Attacker sends spoofed packets (appearing to be from the victim) to sources that then respond to the victim with unwanted traffic	NTP reflection — victim flooded with NTP responses it never requested
Amplification DDoS	A form of reflected attack where responses are much larger than requests, amplifying the impact	DNS amplification — small query to open resolver returns large DNS response to victim

 NOTE

Cloud services cost consideration: Attackers can launch DDoS attacks against cloud-hosted resources (AWS, Azure, Digital Ocean) to deliberately inflate the victim's usage costs — a form of financial DoS.

 IMPORTANT

As a penetration tester, stress testing for availability (simulating DoS) is typically performed in a controlled environment and is out of scope for production systems unless explicitly authorised by the client.

12. NAC Bypass & VLAN Hopping

12.1 Network Access Control (NAC) Bypass

NAC interrogates endpoints before allowing them to join a wired or wireless network. It checks for: security software (antivirus, anti-malware, personal firewalls), OS version and patch level, and compliance with specific policies. NAC is typically used with 802.1X for identity management.

 MAC Auth Bypass (NAC Bypass)

NAC implementations allow specific devices (printers, IP phones, video conferencing) to join the network using an allow-list of MAC addresses — a feature called MAC Authentication Bypass (MAB). An attacker can spoof an authorised MAC address (e.g. spoofing an IP phone's MAC address) to bypass NAC entirely, because ports enabled for MAB are dynamically granted or denied access based solely on the connecting device's MAC address.

12.2 VLAN Hopping

VLAN hopping is a method of gaining access to traffic on other VLANs that would normally not be accessible. There are two primary attack methods:

Method	How It Works	Prevention
Switch Spoofing	Attacker imitates a trunking switch by sending VLAN tag and trunking protocol messages. If the switch port is configured to auto-negotiate trunks (DTP), it establishes a trunk with the attacker's machine, giving access to all VLANs.	Disable DTP on all access ports. Configure all access ports manually — never auto-negotiate trunking.
Double Tagging	Attacker adds two 802.1Q VLAN tags to a frame: the outer tag is their own VLAN, the inner hidden tag is the victim's VLAN. The first switch strips only the outer tag and forwards the frame into the victim's VLAN via the native VLAN.	Never use VLAN 1 as the native VLAN. Use an unused VLAN as native and avoid associating it with any access ports.

12.3 DHCP Starvation & Rogue DHCP Servers

In a DHCP starvation attack, an attacker broadcasts large numbers of DHCP REQUEST messages with spoofed source MAC addresses, exhausting the DHCP server's IP address pool in seconds. Once exhausted, the attacker sets up a rogue DHCP server to respond to new DHCP requests — controlling the IP addresses, gateways, and DNS servers handed out to clients.

TOOL

Yersinia — a tool used to create rogue DHCP servers and launch DHCP starvation and spoofing attacks. Mitigation: Enable DHCP Snooping on switches — only trusted ports (uplinks) are allowed to respond to DHCP requests.

13. Exploiting Wireless Vulnerabilities

13.1 Rogue Access Points

One of the most basic wireless attacks involves an attacker installing a rogue access point (AP) in a network to trick users into connecting to it. The rogue AP creates a backdoor, providing the attacker network access and a man-in-the-middle position.

13.2 Evil Twin Attack



Evil Twin Attack

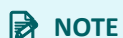
The attacker creates a rogue AP configured identically to the existing corporate wireless network (same SSID, same security settings). DNS spoofing redirects victims to a cloned captive portal or website. When users connect to the evil twin, the attacker injects a spoofed DNS record into the DNS cache — redirecting all connected users.

Captive portals (used in airports, coffee shops) are particularly vulnerable — attackers impersonate them to harvest credentials. Defences: packet filtering, cryptographic protocols, and spoofing detection in modern wireless implementations.

13.3 Disassociation / Deauthentication Attacks

An attacker sends forged deauthentication frames to force legitimate wireless clients to disconnect from their legitimate AP. This can create a DoS condition or force clients to connect to an evil twin. An SSID is the name of an 802.11 network — it is included in plaintext in many wireless packets and beacons.

Tool	Purpose
Kismet / KisMAC	Passive wireless monitoring — captures SSIDs and wireless network traffic without transmitting
Airmon-ng	Part of Aircrack-ng suite — puts wireless adapter into monitor mode for packet capture
Airodump-ng	Part of Aircrack-ng suite — sniffs and analyses wireless network traffic, identifies SSIDs and channels



NOTE

The 802.11w standard defines Management Frame Protection (MFP), which protects against spoofed management frames — including deauthentication frames. MFP is negotiated between the wireless client and the AP. Always enable 802.11w/MFP to defend against deauthentication attacks.

13.4 Preferred Network List (PNL) Attacks

Operating systems and wireless clients maintain a Preferred Network List (PNL) — a list of trusted wireless networks with their SSIDs and credentials. Clients continuously probe for networks in their PNL when not connected. An attacker can listen to these probe requests and impersonate preferred networks — making clients auto-connect to the attacker's device.

13.5 Wireless Signal Jamming

Jamming wireless signals involves generating random noise on the frequencies used by wireless networks, creating a full or partial DoS condition. With packet injection-capable wireless adapters, an attacker can force clients to disconnect from legitimate APs. Most modern wireless implementations include built-in features to immediately detect jamming attacks.

13.6 War Driving

War driving involves driving (or walking) around with a wireless-capable device to discover and catalogue wireless access points. War flying uses drones or UAVs to scan from the air. WiGLE (wigle.net) is a popular site among war drivers that allows users to detect and upload wireless network information via a mobile app.

13.7 WEP Attacks (IV Attacks)

WEP IV Attack

WEP is completely broken and must be avoided. WEP uses RC4 encryption but prepends a 24-bit Initialization Vector (IV) sent in plaintext to the PSK. When WEP encrypts a packet, it prepends the IV to the secret key — giving an attacker the first 3 bytes of the 'secret' key on every packet. Collecting enough data from the air allows full PSK recovery. Injecting ARP packets (predictable length) accelerates the attack dramatically. Tool: Aircrack-ng suite.

13.8 WPA / WPA2 Attacks & KRACK

WPA and WPA2 are susceptible to different vulnerabilities. An attacker can capture the WPA four-way handshake between a client and AP and then brute-force the WPA PSK offline. WPA3 addresses all known WPA/WPA2 vulnerabilities.

KRACK — Key Reinstallation Attack

KRACK vulnerabilities (discovered by Mathy Vanhoef and Frank Piessens, KU Leuven) affect all versions of WPA and WPA2. Exploitation can allow unauthenticated attackers to reinstall a previously used encryption key, then capture and decrypt traffic using the reinstalled key, and forge or replay previously seen traffic. Details: krackattacks.com — Most vendors have patched these vulnerabilities, and WPA3 addresses them at the protocol level.

13.9 WPA3 Vulnerabilities

WPA3 introduced the Dragonfly handshake (using EAP for authentication). Several vulnerabilities affecting WPA3 have been discovered, including side-channel attacks, downgrade attacks, and DoS conditions. Researcher Mathy Vanhoef has documented these at wpa3.mathyvanhoef.com.

NOTE

FragAttacks (Fragmentation and Aggregation Attacks) is another class of vulnerabilities that affect WPA3 — allowing an attacker to inject arbitrary network packets or decrypt data. Details and demos: fragattacks.com

13.10 WPS PIN Attacks

WPS PIN Brute Force

Wi-Fi Protected Setup (WPS) simplifies wireless network deployment using an 8-digit PIN printed on the device. Most WPS implementations do not limit failed PIN attempts — making them vulnerable to brute-force attacks. An attacker can try millions of PIN combinations to recover the WPA PSK. Tool: Reaver (github.com/t6x/reaver-wps-fork-t6x)

13.11 KARMA Attacks

KARMA (Karma Attacks Radio Machines Automatically) is an on-path attack that creates a rogue AP. The attacker listens for probe requests from wireless devices and responds by creating an AP with the exact

SSID the device is probing for, making clients auto-connect. KARMA attacks exploit the PNL (Preferred Network List) vulnerability.

13.12 Credential Harvesting via Wireless

Credential harvesting attacks obtain user credentials through fake wireless infrastructure. Tools like Ettercap can spoof DNS replies to divert users from legitimate websites to attacker-controlled clones (e.g. a fake Twitter login page). The Social-Engineer Toolkit (SET, from Module 4) also supports wireless-based credential harvesting by impersonating captive portals.

14. Bluetooth, BLE & RFID Attacks

14.1 Bluejacking

Bluejacking sends unsolicited messages to Bluetooth-enabled devices in range using the Object Exchange (OBEX) protocol. An attacker sends a vCard (contact card) where the name field contains a message. This is primarily used as a form of Bluetooth spam. A vCard can contain names, addresses, phone numbers, emails, and URLs.

14.2 Bluesnarfing



Bluesnarfing

Bluesnarfing obtains unauthorised access to information on a Bluetooth-enabled device. Attackers can steal calendars, contact lists, emails and text messages, pictures, and videos. Bluesnarfing can also extract the IMEI (International Mobile Equipment Identity) number — allowing the attacker to divert incoming calls and messages to another device.

Bluesnarfing is more dangerous than Bluejacking: Bluejacking only transmits data TO the victim, while Bluesnarfing actively steals data FROM the victim.

14.3 Bluetooth Low Energy (BLE) Attacks

Numerous IoT devices use BLE for communication. BLE is susceptible to on-path attacks (modifying messages between systems), DoS attacks, and fingerprinting attacks (which can reveal design flaws and

misconfigurations of BLE devices). Ohio State University researchers have documented BLE fingerprinting attacks in detail.

14.4 RFID Attacks

Radio-frequency identification (RFID) uses electromagnetic fields to identify and track tags. Active RFID tags have local power sources; passive tags use energy from RFID readers. RFID is used in inventory tracking, building access badges, and even implants.

RFID Frequency	Range	Common Use
Low-Frequency (LF) 120–140 kHz	< 3 feet	Access control, animal tracking
High-Frequency (HF) 13.56 MHz	3–10 feet	Smart cards, NFC payments, library books
Ultra-High-Frequency (UHF) 860–960 MHz	Up to 30 feet	Retail inventory, supply chain tracking

Common RFID Attack Methods

- **Silent theft:** An attacker with an RFID reader (e.g. Proxmark3) can silently capture RFID data (badge, tag) simply by walking near the victim
- **RFID cloning:** The captured RFID data is written to a blank tag, which can then be used to enter buildings or rooms
- **Skimmers:** Physical RFID skimmers implanted behind legitimate card readers capture credentials from unsuspecting users
- **NFC amplification:** Amplified antennas extend the normal range of RFID/NFC reads, enabling attacks from much longer distances — including password and encryption key exfiltration

15. Password Spraying & Exploit Chaining

15.1 Password Spraying



Password spraying brute-forces authentication by trying one common password (e.g. 'password1', 'Summer2024!') across a large list of usernames — instead of trying many passwords against one account. This avoids account lockout policies that trigger after multiple failed attempts on a single account.

15.2 Credential Stuffing

Credential stuffing performs automated injection of username/password pairs exposed in previous data breaches. Unlike password spraying, the attacker uses real credentials from breach databases (not guessed passwords). Since many users reuse passwords across services, these attacks are highly effective. Reference: owasp.org/www-community/attacks/Credential_stuffing

Attack	What It Uses	Target
Password Spraying	One common password tried against many usernames	Avoids lockout — targets entire organisation
Credential Stuffing	Real username/password pairs from prior data breaches	Users who reuse passwords across services
Brute Force	Every possible password tried against one account	Single account — triggers lockout policies

15.3 Exploit Chaining

Most sophisticated attacks leverage multiple vulnerabilities in sequence. An attacker 'chains' exploits against known or zero-day vulnerabilities to compromise systems, steal, modify, or corrupt data. For example, a low-severity LLMNR poisoning attack may lead to credential capture, which enables a pass-the-hash attack, which provides domain access, which enables a Kerberos golden ticket attack — a full domain compromise through chained exploits.

 KEY CONCEPT

Exploit chaining means that even a 'low-severity' vulnerability should never be ignored in isolation. In combination with other weaknesses, it may form part of a chain leading to full system or domain compromise.

16. Module Summary & Key Takeaways



REMEMBER

Network-based attacks operate at every layer of the OSI model — from Layer 2 ARP spoofing to Layer 7 SMTP open relays. A comprehensive defence requires controls at every layer, combined with strong credential management, patching, and monitoring.

Key Takeaways

5. LLMNR/NBT-NS poisoning captures NTLMv2 hashes passively — disable LLMNR and NetBIOS where not needed.
6. EternalBlue (MS17-010) is the most impactful SMB exploit ever released — always patch Windows systems promptly.
7. Pass-the-hash bypasses the need for plaintext passwords — protect the SAM file and use Mimikatz awareness in defences.
8. Kerberos golden tickets grant unlimited domain access — protect the KRBTGT account hash at all costs.
9. Kerberoasting requires no domain admin credentials and sends no packets to the victim — use strong service account passwords.
10. On-path attacks operate at Layer 2 (ARP) and Layer 3 (routing) — defend with DAI, 802.1X, and route filtering.
11. DoS/DDoS comes in four forms: direct, botnet, reflected, and amplification — each requiring different defences.
12. VLAN 1 should never be used as the native VLAN — use switch spoofing and double-tagging prevention techniques.
13. WEP is completely broken — WPA3 with MFP (802.11w) is the recommended wireless security standard.
14. Bluetooth attacks (Bluejacking, Bluesnarfing) and RFID cloning (Proxmark3) are real physical-layer threats.
15. Password spraying avoids lockouts — combine strong password policies with MFA to defend effectively.
16. Exploit chaining means no vulnerability is truly low-risk in isolation — remediate everything.

Quick Reference: Attack & Defence

Attack	Protocol/Layer	Key Defence
--------	----------------	-------------

LLMNR Poisoning	UDP 5355 / Layer 3	Disable LLMNR and NetBIOS via Group Policy
SMB / EternalBlue	TCP 445 / Layer 7	Patch Windows, disable SMBv1, block externally
DNS Cache Poisoning	UDP 53 / Layer 7	DNSSEC, restrict recursive queries
SNMP Enumeration	UDP 161 / Layer 7	SNMPv3 only, change defaults, block untrusted hosts
SMTP Open Relay	TCP 25 / Layer 7	Disable VRFY/EXPN, require authentication
Pass-the-Hash	NTLM / Kerberos	Credential Guard, MFA, network segmentation
Golden Ticket	Kerberos	Protect KRBTGT, monitor for anomalous TGT usage
ARP Spoofing	Layer 2	Dynamic ARP Inspection (DAI) on switches
VLAN Hopping	802.1Q / Layer 2	Disable DTP, never use VLAN 1 as native
DHCP Starvation	UDP 67-68 / Layer 7	DHCP Snooping on switches
Evil Twin / KARMA	802.11 / Wireless	802.1X, certificate-based auth, 802.11w (MFP)
WPS PIN Brute Force	802.11 / Wireless	Disable WPS entirely
Bluejacking/Bluesnarfing	Bluetooth	Disable Bluetooth discoverability, keep devices patched
Password Spraying	Authentication	MFA, account lockout, anomalous login monitoring

End of Module 5